black hat

USA 2020

AUGUST 5-6, 2020

ARSENAL

#BHUSA @BLACKHATEVENTS

Manuka

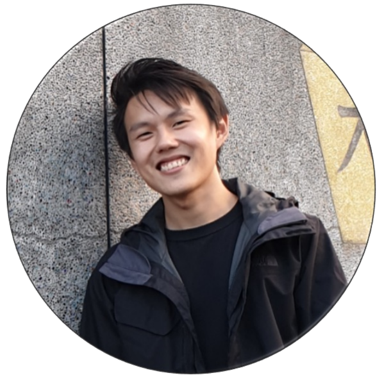
A modular, scalable OSINT honeypot targeting pre-attack reconnaissance techniques.

Brought to you by:

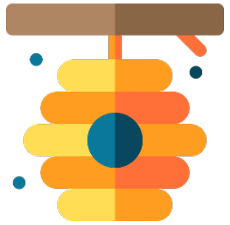

Eugene Lim


Bernard Lim


Kenneth Tan


Tan Kee Hock

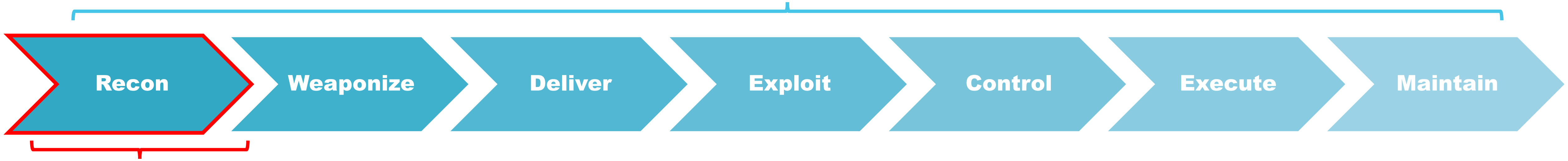
Modern honeypots tend to focus on the later stages of the cyber kill chain.



Honeypots
A set of systems designed to trick adversarial entities that it is a legitimate target.

1. Divert malicious traffic away from important systems
2. Provides early warning
3. Gather information about the attackers and their methods

Most honeypots create simulated environments to "trap" attackers conducting later stages of the cyber kill chain. Conventional honeypots work perfectly to capture data from various stages of the cyber kill chain.



However, there were **limited developments to capture data generated during reconnaissance phase**.

Source:
https://www.kaspersky.com/resource-center/threats/what-is-a-honeypot
https://www.forbes.com/sites/forbestechcouncil/2020/01/28/when-you-cant-stop-every-cyberattack-try-honeypots/#3f42bb336cf2

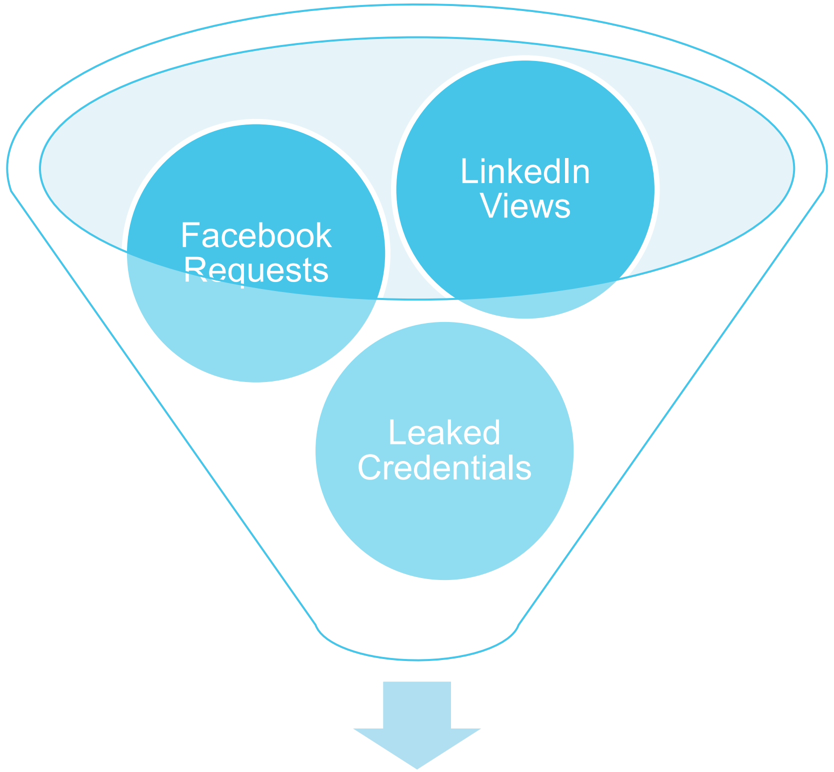
There are very few honeypots on the market that target reconnaissance activity.

Google Hack Honeypot (GHH)
Designed to provide reconnaissance against attackers that use search engines as a hacking tool against your resources. GHH implements honeypot theory to provide additional security. It creates fake webpages only found by web crawlers and Google spiders, to learn about attackers doing reconnaissance on the site.

With reference to MITRE's PRE-ATT&CK Tactics, there are areas in which current honeypot systems do not address, such as capturing reconnaissance data when attackers perform **"People Information Gathering"**.

Source:
http://ghh.sourceforge.net/
https://github.com/paralax/awesome-honeypots

How can we make sense of the noise generated by reconnaissance?



Noise: Potential Indicators of Interest

There are almost no tools on the market that target this noise! Analyzing potential indicators of interest can help organizations shift left in their defense posture.

Manuka monitors reconnaissance attempts by threat actors and generates actionable intelligence.

Manuka

- Sets up simulated environment
- Stages OSINT sources e.g. social media profiles
- Tracks signs of adversary interest

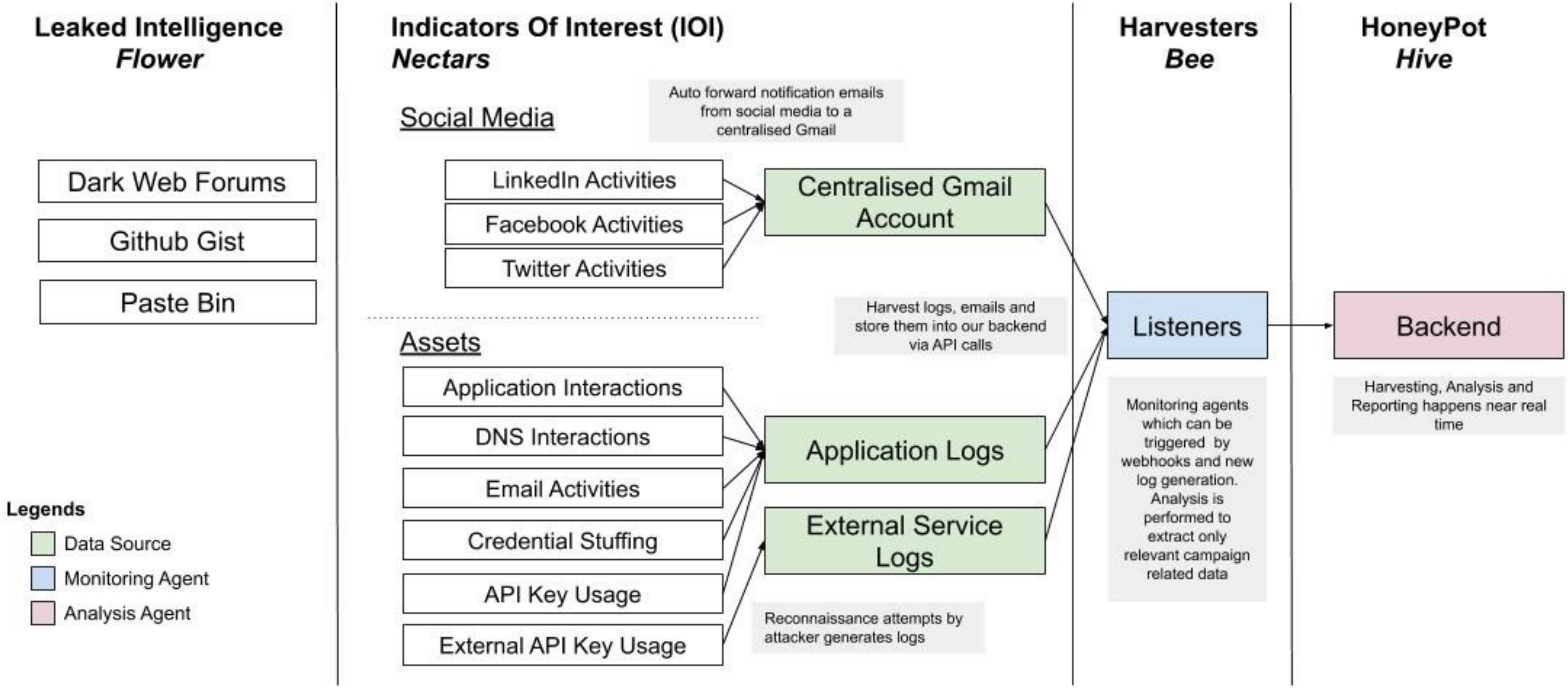
"Are there signs that adversarial entities are performing reconnaissance on us?"

Manuka offers a simple 3-step process to get started.

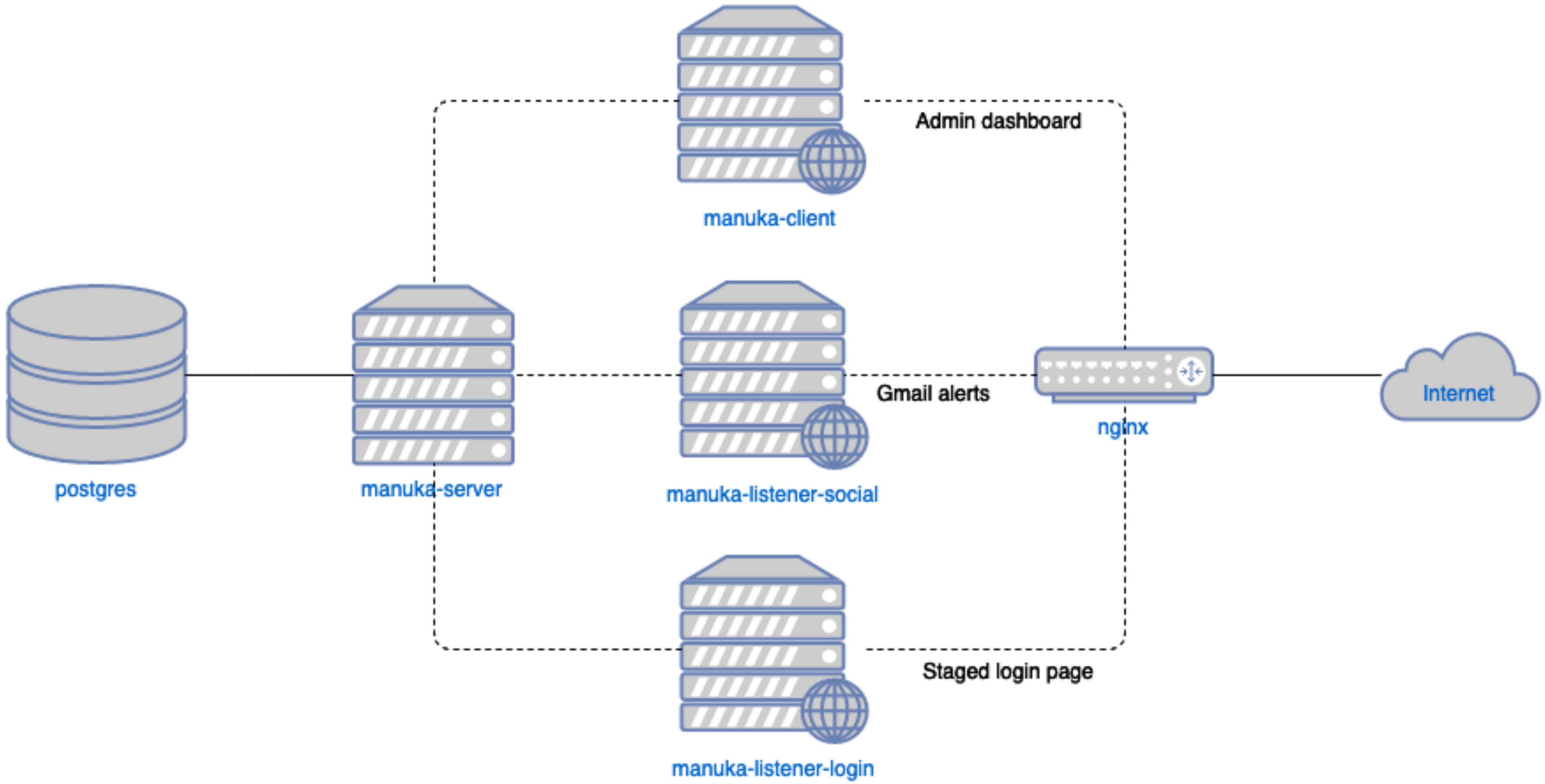
Manuka is written in GO and deployed with Docker! The architecture is designed to be highly modular and extensible! Pull requests are welcomed!

Manuka

1. **Configure**
   Set up your mail inbox auto-forwarding, social media profiles, and API keys
2. **Deploy**
   `docker-compose up`
3. **Respond**
   Analyze the incoming intelligence and automate responses



Architecture Diagram



System Design

Current Features

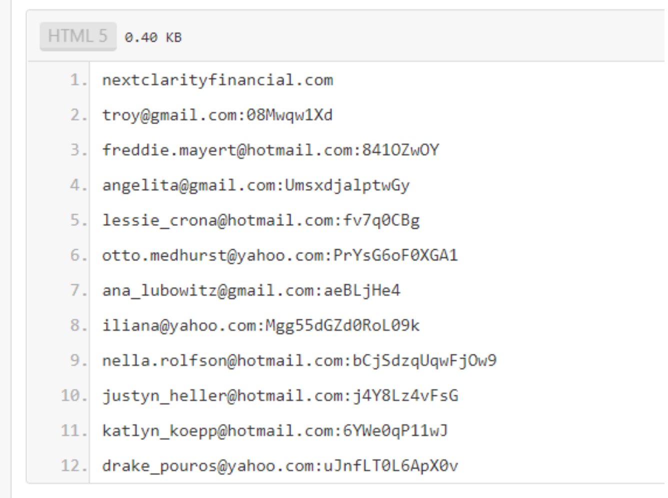
- Supports detection of social events on LinkedIn and Facebook
- Supports login detection of credentials (posted on Pastebin)

In-Development

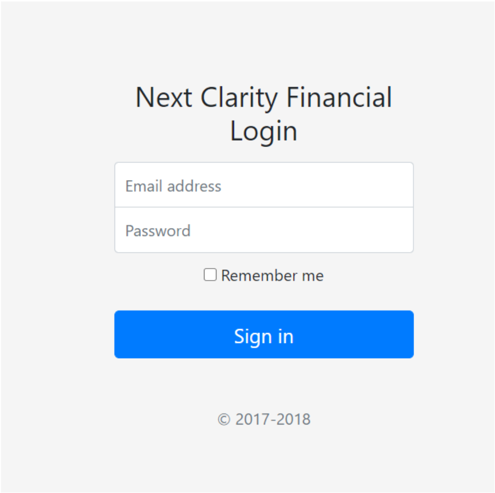
- Automated setup with other text storage sites (e.g. gist)
- Research on building other social media listeners (e.g. Instagram)

Future Development

- Integration with conventional honeypot systems
- Automated responses
- Contextualization of intelligence

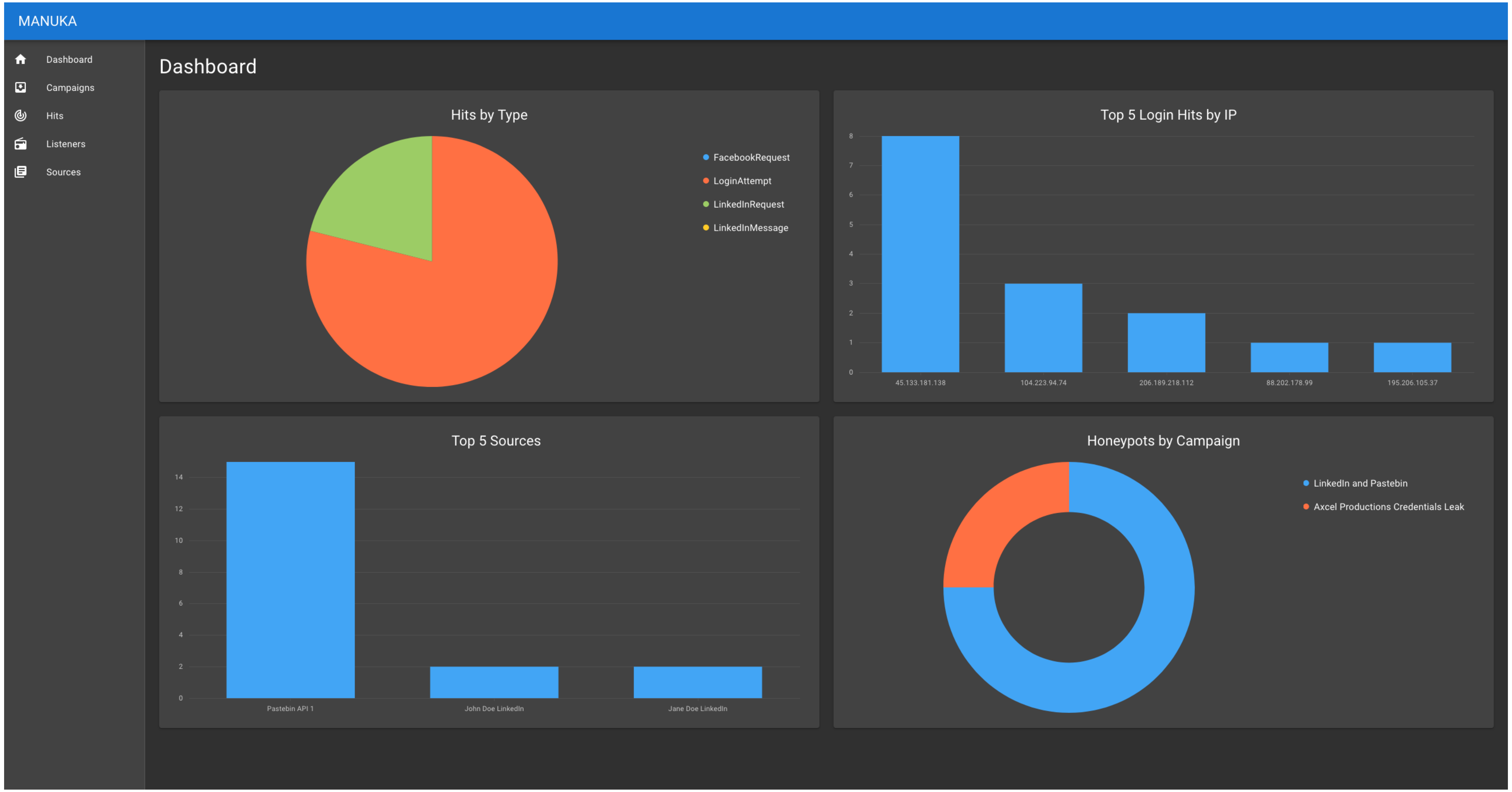


Generated leaks are pushed to pastebin



Honeypot web login

Current state of development supports research use-cases. More development is needed to make it enterprise-ready!



Manuka Intelligence Dashboard

Demonstration

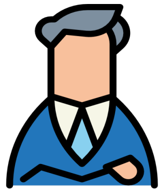
Sit back, relax and watch our video!

Demonstration Scenario

Demonstration Scenario

Next Clarity Financial
Increase the transparency of Financial Institutions using Distributed Ledger Technology.

As the cybersecurity lead, you observed the company has been receiving **an increased number of phishing emails** recently.



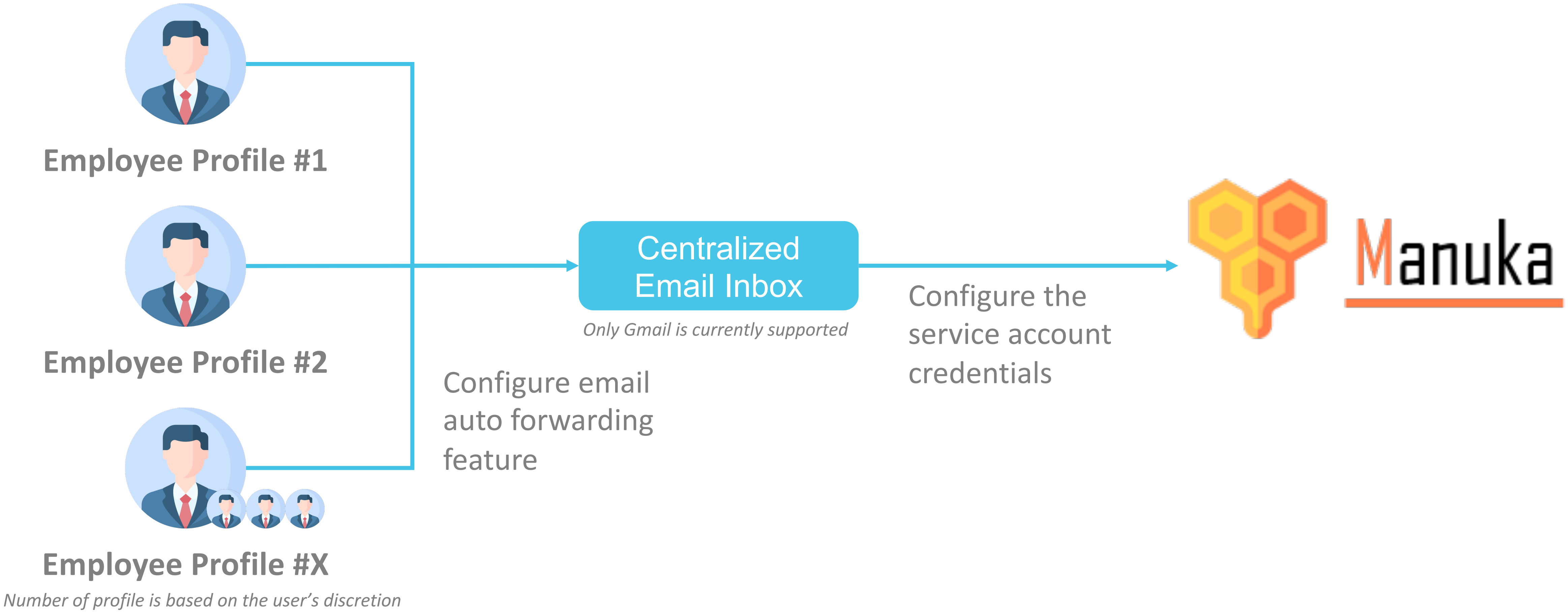
Management

Concerned if the increase in phishing emails are indicative of any risks!

You

Discovered Manuka and wanted to use it collect more data for analysis! You want to investigate if there are any sign of adversarial interest on the organization!

Manuka Prerequisites



Manuka offers use cases for both enterprises and researchers.

For Enterprises

1. Organization is keen to understand internet/threat actors' interest level of them
2. Improve security posture through automated remediation to address risk areas based on intelligence produced by Manuka

For Security Researchers

1. Investigation of the relationship between social media and an organization's cybersecurity risk posture

Question and Answers

Feel free to share with us your thoughts!

https://github.com/spaceraccoon/manuka

Manuka

ID	Name	Description
TA0012	Priority Definition Planning	Priority definition planning consists of the process of determining the set of Key Intelligence Topics (KIT) or Key Intelligence Questions (KIQ) required for meeting key strategic, operational, or tactical goals. Leadership outlines the priority definition (may be considered a goal) around which the adversary designs target selection and a plan to achieve. An analyst may outline the priority definition when in the course of determining gaps in existing KITs or KIQs.
TA0013	Priority Definition Direction	Priority definition direction consists of the process of collecting and assigning requirements for meeting Key Intelligence Topics (KIT) or Key Intelligence Questions (KIQ) as determined by leadership.
TA0014	Target Selection	Target selection consists of an iterative process in which an adversary determines a target by first beginning at the strategic level and then narrowing down operationally and tactically until a specific target is chosen. A target may be defined as an entity or object that performs a function considered for possible engagement or other action.
TA0015	Technical Information Gathering	Technical information gathering consists of the process of identifying critical technical elements of intelligence an adversary will need about a target in order to best attack. Technical intelligence gathering includes, but is not limited to, understanding the target's network architecture, IP space, network services, email format, and security procedures.
TA0016	People Information Gathering	People Information Gathering consists of the process of identifying critical personnel elements of intelligence an adversary will need about a target in order to best attack. People intelligence gathering focuses on identifying key personnel or individuals with critical accesses in order to best approach a target for attack. It may involve aspects of social engineering, elicitation, mining social media sources, or be thought of as understanding the personnel element of competitive intelligence.
TA0017	Organizational Information Gathering	Organizational information gathering consists of the process of identifying critical organizational elements of intelligence an adversary will need about a target in order to best attack. Similar to competitive intelligence, organizational intelligence gathering focuses on understanding the operational tempo of an organization and gathering a deep understanding of the organization and how it operates, in order to best develop a strategy to target it.
TA0018	Technical Weakness Identification	Technical weakness identification consists of identifying and analyzing weaknesses and vulnerabilities collected during the intelligence gathering phases to determine best approach based on technical complexity and adversary priorities (e.g., expediency, stealthiness).

ID	Name	Description
TA0019	People Weakness Identification	People weakness identification consists of identifying and analyzing weaknesses and vulnerabilities from the intelligence gathering phases which can be leveraged to gain access to target or intermediate target persons of interest or social trust relationships.
TA0020	Organizational Weakness Identification	Organizational weakness identification consists of identifying and analyzing weaknesses and vulnerabilities from the intelligence gathering phases which can be leveraged to gain access to target or intermediate target organizations of interest.
TA0021	Adversary OPSEC	Adversary OPSEC consists of the use of various technologies or 3rd party services to obfuscate, hide, or blend in with accepted network traffic or system behavior. The adversary may use these techniques to evade defenses, reduce attribution, minimize discovery, and/or increase the time and effort required to analyze.
TA0022	Establish & Maintain Infrastructure	Establishing and maintaining infrastructure consists of building, purchasing, co-opting, and maintaining systems and services used to conduct cyber operations. An adversary will need to establish infrastructure used to communicate with and control assets used throughout the course of their operations.
TA0023	Persona Development	Persona development consists of the development of public information, presence, history and appropriate affiliations. This development could be applied to social media, website, or other publicly available information that could be referenced and scrutinized for legitimacy over the course of an operation using that persona or identity.
TA0024	Build Capabilities	Building capabilities consists of developing and/or acquiring the software, data and techniques used at different phases of an operation. This is the process of identifying development requirements and implementing solutions such as malware, delivery mechanisms, obfuscation/cryptographic protections, and call back and O&M functions.
TA0025	Test Capabilities	Testing capabilities takes place when adversaries may need to test capabilities externally to refine development goals and criteria and to ensure success during an operation. Certain testing may be done after a capability is staged.
TA0026	Stage Capabilities	Staging capabilities consists of preparing operational environment required to conduct the operation. This includes activities such as deploying software, uploading data, enabling command and control infrastructure.